

Challenge: JetBrains Lab

Platform: SOC Analyst Tier 1

Category: Network Forensics

Tactics: Initial AccessExecutionCommand and Control

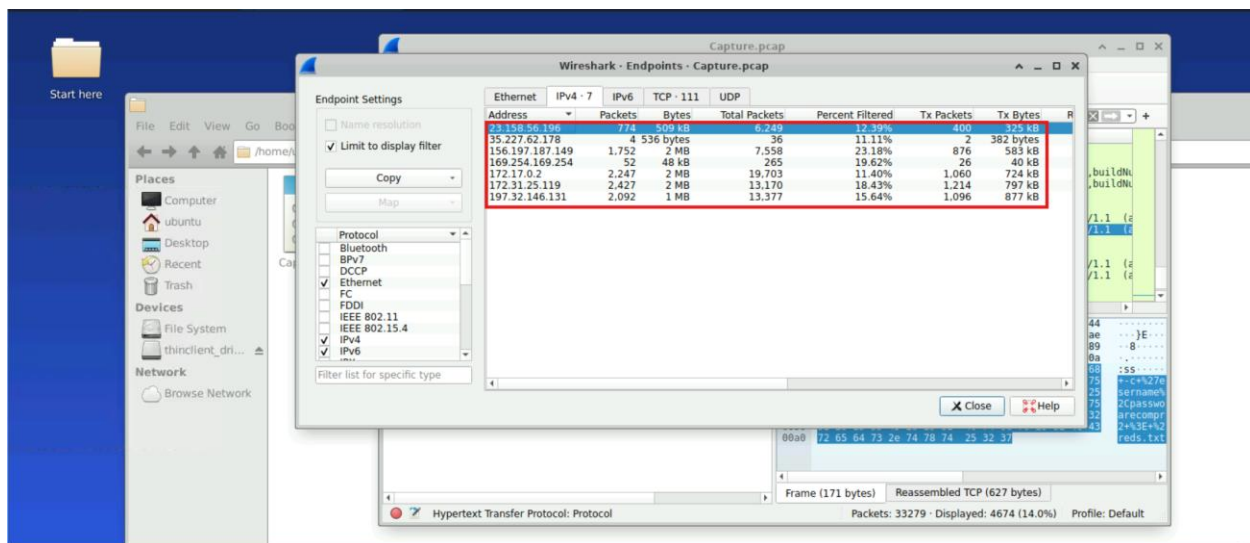
Tools: WiresharkNetworkMinerBrim

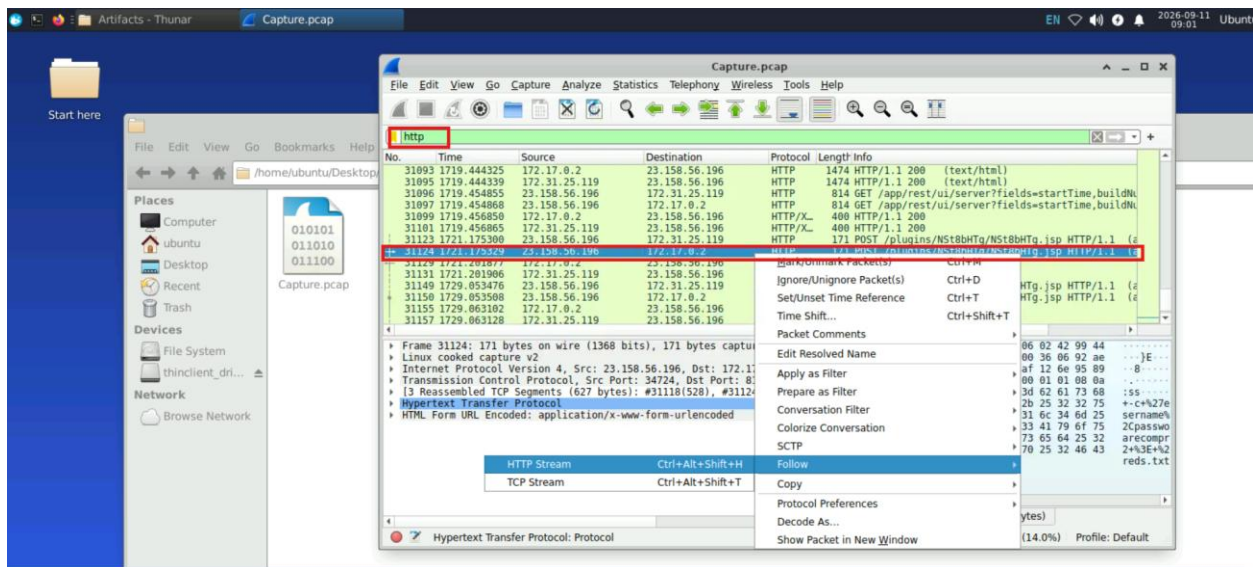
Kịch bản:

- During a recent security incident, an attacker successfully exploited a vulnerability in our web server, allowing them to upload webshells and gain full control over the system. The attacker utilized the compromised web server as a launch point for further malicious activities, including data manipulation.
- As part of the investigation, You are provided with a packet capture (PCAP) of the network traffic during the attack to piece together the attack timeline and identify the methods used by the attacker. The goal is to determine the initial entry point, the attacker's tools and techniques, and the compromise's extent.

Q1

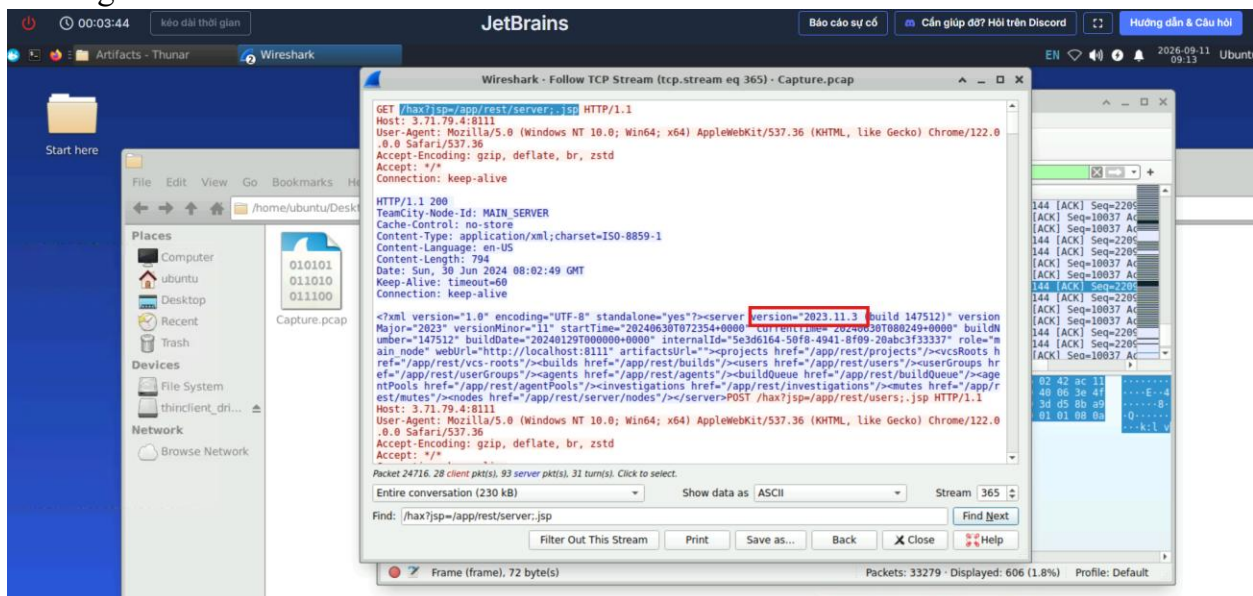
Identifying the attacker's IP address helps trace the source and stop further attacks. What is the attacker's IP address?





Q2

To identify potential vulnerability exploitation, what version of our web server service is running?



Q3

After identifying the version of our web server service, what CVE number corresponds to the vulnerability the attacker exploited?

Khi xem xét thông tin cập nhật từ trang vấn đề bảo mật JetBrains, rõ ràng lỗ hổng liên quan đến phiên bản TeamCity bị xâm nhập () phù hợp với **CVE-2024-27198**. CVE này mô tả một lỗ hổng vượt qua xác thực quan trọng, cho phép kẻ tấn công thực hiện các hành động quản trị mà không cần sự cho phép hợp lệ. Lỗ hổng này được phân loại là

ng nghiêm trọng do có khả năng trao quyền kiểm soát rộng rãi cho người dùng không được phép đối với hệ thống bị ảnh hưởng.2023.11.3 (Build 147512)

Privacy & Security

Privacy & SecurityTrust CenterDigital SignaturesFixed IssuesSecurity NotificationsOur Commitment

Fixed security issues

This page contains information about resolved security issues, including description, severity, assigned CVEs, and the product versions in which they were resolved.

Product

TeamCity

Fix version

2023.11.4

Product	Description	Severity	Resolved In	CWE	CVE
TeamCity	Custom build parameters of the "password" type could be disclosed (TW-86403)	Medium	2023.11.4	CWE-201	CVE-2024-28173
TeamCity	Presigned URL generation requests in S3 Artifact Storage plugin were authorized improperly (TW-85562)	Medium	2023.11.4	CWE-863	CVE-2024-28174
TeamCity	Authentication bypass allowing to perform admin actions was possible. Reported by Rapid7 team (TW-86500)	Critical	2023.11.4	CWE-288	CVE-2024-27198
TeamCity	Path traversal allowing to perform limited admin actions was possible. Reported by Rapid7 team (TW-86502)	High	2023.11.4	CWE-23	CVE-2024-27199

Q4

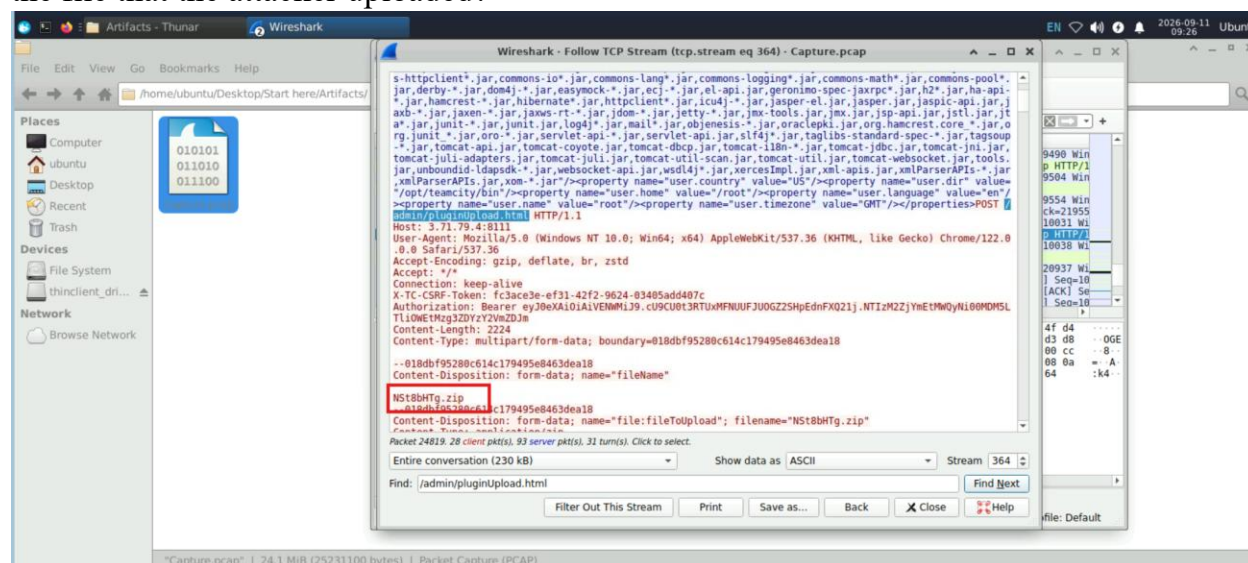
What credentials did the attacker successfully use for Basic Auth against the TeamCity server?

Các thông tin xác thực mà câu hỏi hỏi là những thông tin mà kẻ tấn công đã sử dụng để xác thực vào TeamCity REST API thông qua HTTP Basic Auth.

Lệnh nhúng trong payload HTTP bao gồm các thông tin xác thực sau: và . Ngoài ra, kẻ tấn công đã cấp cho người dùng một địa chỉ email (C19oyem@example.com) và cấp quyền nâng cao bằng cách gán vai trò đó.username: c91oyemwpassword: CL5vzdwLuKSYSTEM_ADMIN

Q5

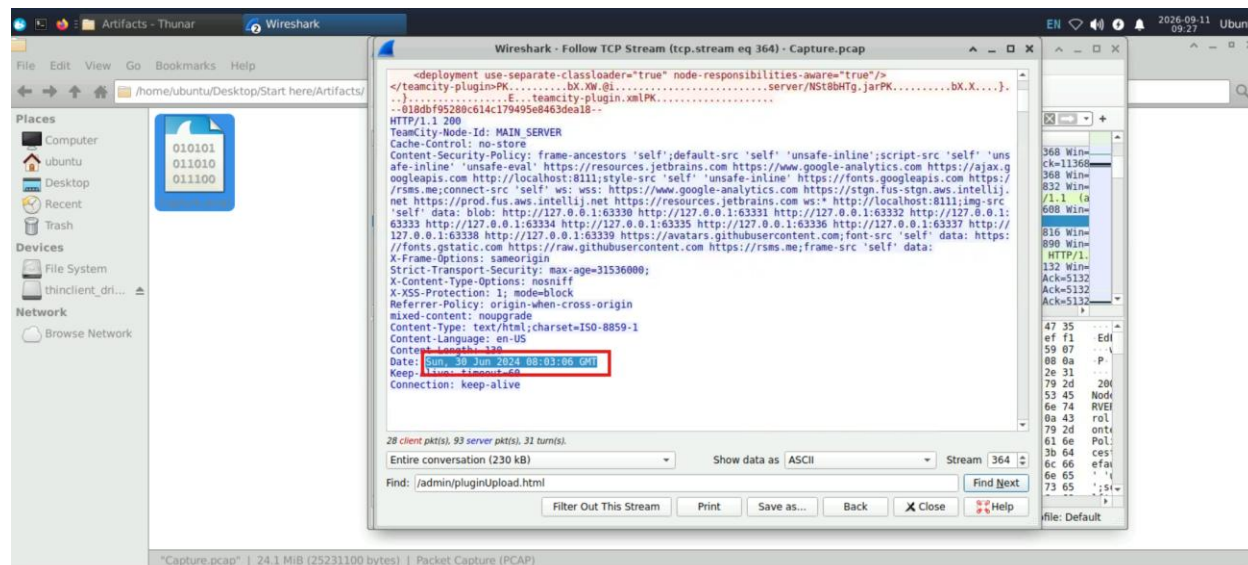
The attacker uploaded a webshell to ensure his access to the system. What is the name of the file that the attacker uploaded?



Q6

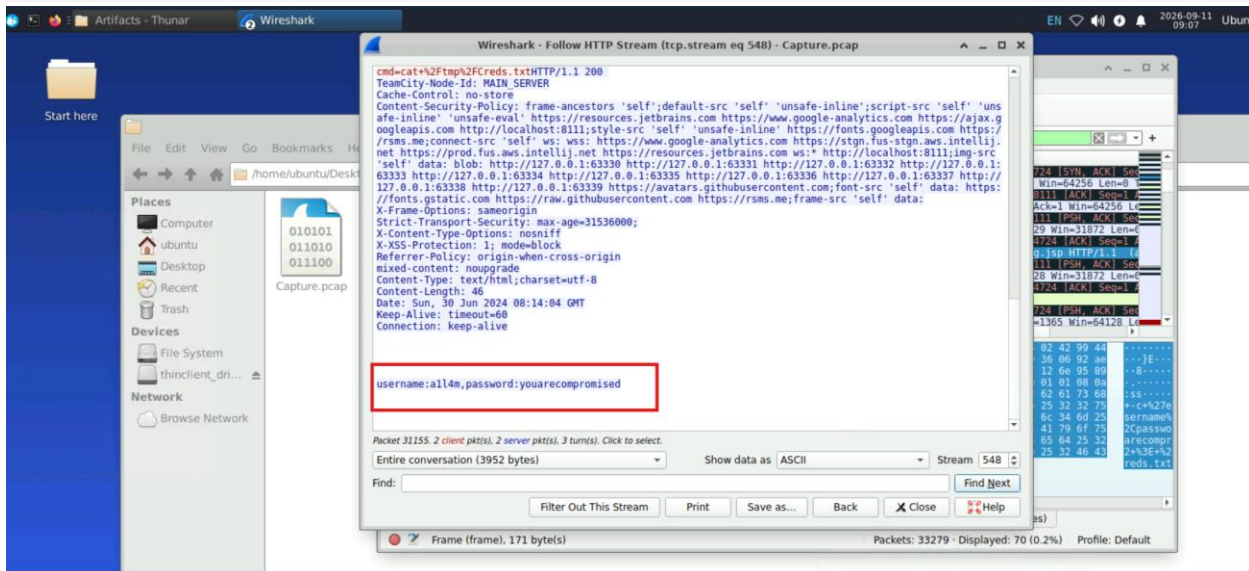
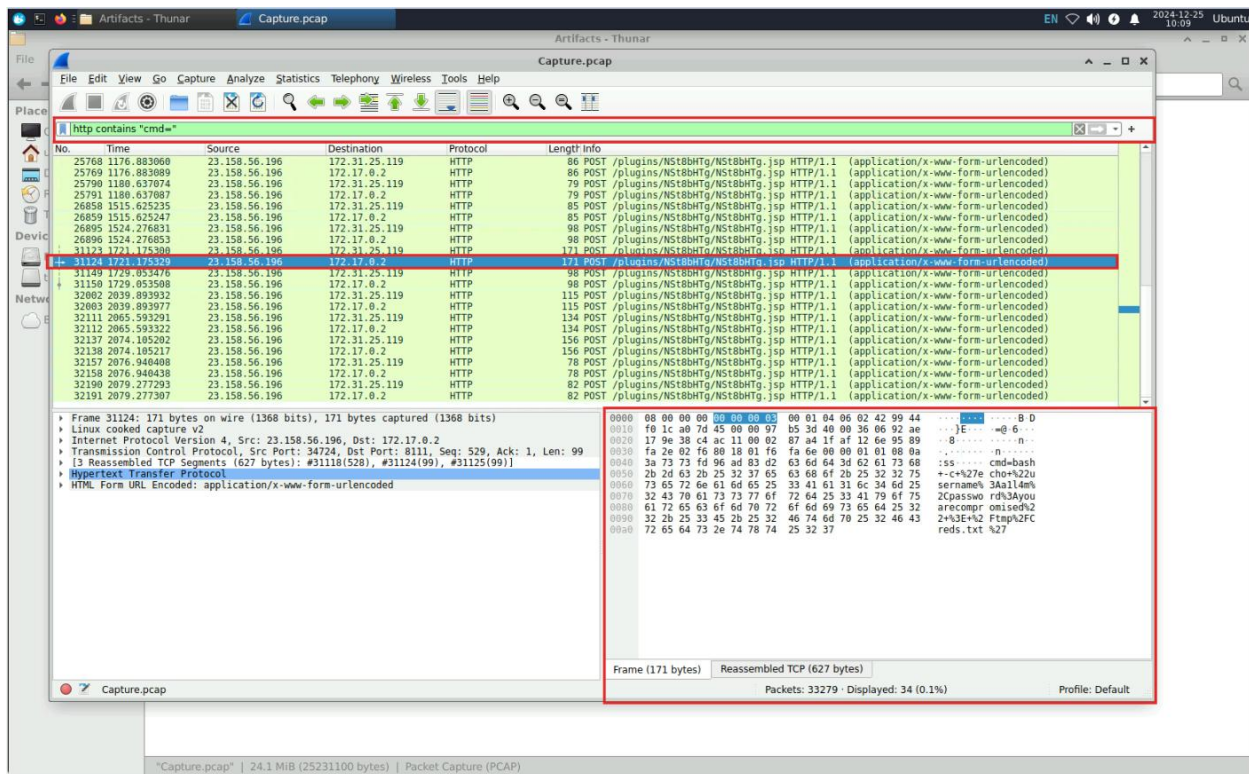
When did the attacker execute their first command via the web shell?

YYYY-MM-DD HH:MM



Q7

The attacker tampered with a text file that contained the credentials of the admin user of the webserver. What new username and password did the attacker write in the file?



Q8

showed the attacker writing false credentials into . Which MITRE ATT&CK sub-technique (Data Manipulation family) describes that specific file-write action?

Dựa trên bối cảnh hoạt động giả mạo tệp của kẻ tấn công, kỹ thuật con MITRE ATT&CK liên quan trong danh mục Thao túng Dữ liệu là T1565.001 - Thao túng Dữ liệu: Dữ liệu được lưu trữ.

The screenshot shows the MITRE ATT&CK framework page for T1565.001, titled "Stored Data Manipulation". The page is categorized under "Data Manipulation" and "Stored Data Manipulation". It includes a description of the technique, which involves inserting, deleting, or manipulating data at rest to influence external outcomes or hide activity. The page also lists various sub-techniques and provides a link to the MITRE Reference.

Q9

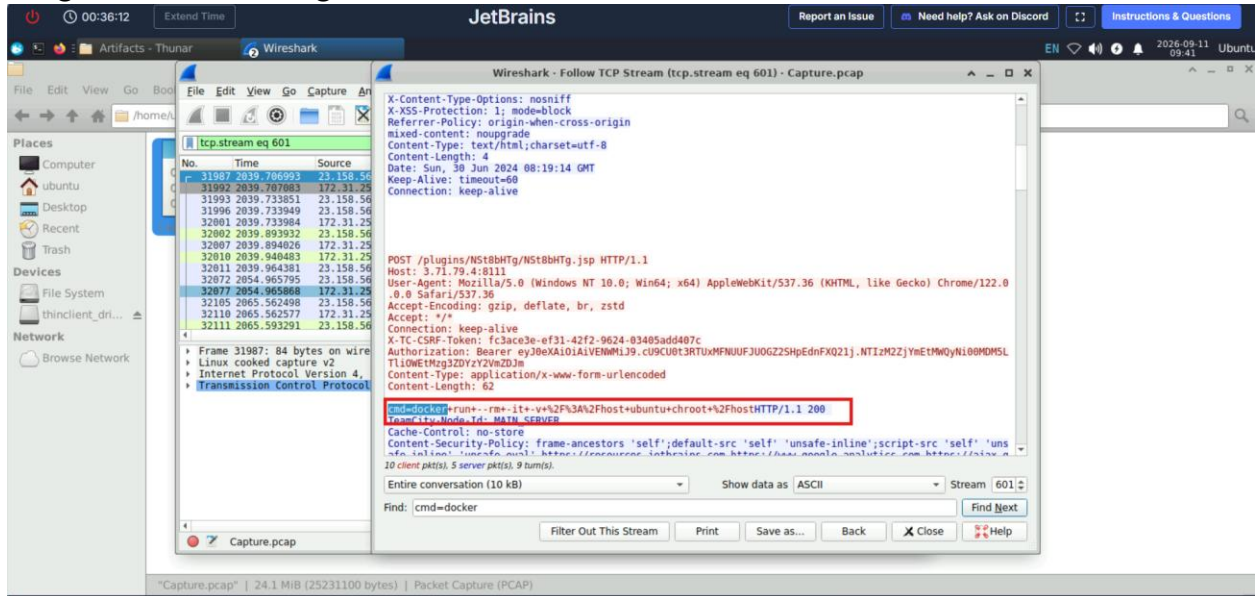
Immediately after gaining a shell, the attacker executed a docker command that mounted the host filesystem and chrooted into it — providing full host access. What was that exact command?

The screenshot shows a Wireshark packet capture of an HTTP request. The packet is a POST request to the endpoint `/plugins/NS8t8BHTg/NS8t8BHTg.jsp`. The request body contains a Docker command: `cmd=docker+run+--rm+it+--privileged+ubuntuHTTP/1.1 200`. The command is highlighted in red in the original image. The packet is part of a TCP stream (eq 601) and is captured on the interface `eth0`.

Kẻ tấn công đã thực thi lệnh: `cmd=docker run --rm -it --privileged ubuntu`

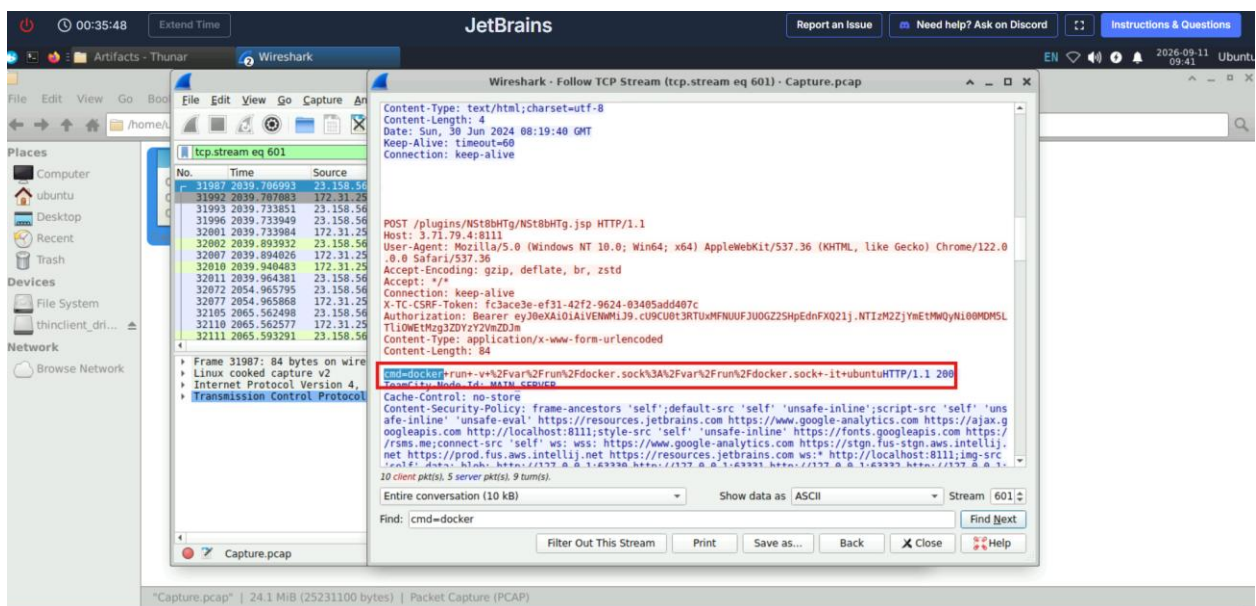
➔ Dùng để khởi động một container Docker mới với quyền cao hơn. Kẻ tấn công sử dụng hình ảnh để khởi động container một cách tương tác () và gỡ bỏ nó () sau khi nó thoát ra.

Tuy nhiên không thành công do hạn chế quyền của Docker, các lệnh khác của kẻ tấn công sau đó đã sử dụng.



cmd=docker run --rm -it -v /:/host ubuntu chroot /host

Lệnh này cố gắng gắn toàn bộ hệ thống tệp gốc () của máy chủ vào container. dùng lệnh để thay đổi thư mục gốc của môi trường shell container thành cho phép hoạt động trong bối cảnh hệ thống tệp tin của máy chủ.



cmd=docker run -v /var/run/docker.sock:/var/run/docker.sock -it ubuntu

Lệnh này gắn socket Docker () từ máy chủ vào container. Socket Docker là một socket miền UNIX được sử dụng để giao tiếp với daemon Docker. Bằng cách truy cập, kẻ tấn công có thể điều khiển trực tiếp daemon Docker từ bên trong container. Kiểm soát này cho phép họ khởi động container mới, thực thi lệnh, hoặc thậm chí truy cập vào máy chủ bằng cách chạy container với quyền nâng cao. Cách tiếp cận này là một phương pháp đã biết và hiệu quả để phá vỡ container nếu các kiểm soát truy cập đúng trên socket Docker không được thực thi. /var/run/docker.sock